

Индивидуальный проект. Этап 2

Установка DVWA

Богданюк Анна Васильевна

Содержание

1	Цель работы	1
2	Задание.....	1
3	Теоретическое введение	1
4	Выполнение лабораторной работы	2
5	Выводы.....	4

1 Цель работы

Установить DVWA в гостевую систему к Kali Linux.

2 Задание

1. Установить DVWA в гостевую систему к Kali Linux.

3 Теоретическое введение

Некоторые из уязвимостей веб приложений, который содержит DVWA: - Брутфорс: Брутфорс HTTP формы страницы входа - используется для тестирования инструментов по атаке на пароль методом грубой силы и показывает небезопасность слабых паролей. - Исполнение (внедрение) команд: Выполнение команд уровня операционной системы. - Межсайтовая подделка запроса (CSRF): Позволяет «атакующему» изменить пароль администратора приложений. - Внедрение (инклюд) файлов: Позволяет «атакующему» присоединить удалённые/локальные файлы в веб приложение. -SQL внедрение: Позволяет «атакующему» внедрить SQL выражения в HTTP из поля ввода, DVWA включает слепое и основанное на ошибке SQL внедрение. - Небезопасная выгрузка файлов: Позволяет «атакующему» выгрузить вредоносные файлы на веб сервер. - Межсайтовый скриптинг (XSS): «Атакующий» может внедрить свои скрипты в веб приложение/базу данных. DVWA включает отражённую и хранимую XSS. - Пасхальные яйца: раскрытие полных путей, обход аутентификации и некоторые другие.

DVWA имеет три уровня безопасности, они меняют уровень безопасности каждого веб приложения в DVWA: 1. Невозможный — этот уровень должен быть безопасным от всех уязвимостей. Он используется для сравнения уязвимого исходного кода с безопасным исходным кодом. 2. Высокий — это расширение среднего уровня сложности, со смесью более сложных или альтернативных плохих практик в попытке обезопасить код. Уязвимости не позволяют такой простор эксплуатации как на других уровнях. 3. Средний — этот уровень безопасности предназначен главным образом для того, чтобы дать пользователю пример плохих практик безопасности, где разработчик попытался сделать приложение безопасным, но потерпел неудачу. 4. Низкий — этот уровень безопасности совершенно уязвим и совсем не имеет защиты. Его предназначение быть примером среди уязвимых веб приложений, примером плохих практик программирования и служить платформой обучения базовым техникам эксплуатации.

4 Выполнение лабораторной работы

Переходим в директорию /var/www/html, потому что настройка dvwa происходит на локальном хосте (рис. 1).

```
(avbogdanyuk@ avbogdanyuk)-[~]  
$ cd /var/www/html
```

Директория

Далее клонирую нужный репозиторий GitHub (рис. 2).

```
(avbogdanyuk@ avbogdanyuk)-[/var/www/html]  
$ sudo git clone http://github.com/ethicalhack3r/DVWA  
Клонирование в «DVWA» ...  
warning: переадресация на https://github.com/ethicalhack3r/DVWA/  
remote: Enumerating objects: 5105, done.  
remote: Counting objects: 100% (91/91), done.  
remote: Compressing objects: 100% (24/24), done.  
remote: Total 5105 (delta 79), reused 67 (delta 67), pack-reused 5014 (from 4)  
)  
Получение объектов: 100% (5105/5105), 2.45 МиБ | 4.68 МиБ/с, готово.  
Определение изменений: 100% (2504/2504), готово.
```

Клонирую репозиторий

Проверяю, чтобы всё скопировалось верно, затем повышаю права доступа к DVWA до 777 (рис. 3).

```
(avbogdanyuk@ avbogdanyuk)-[/var/www/html]  
$ ls  
DVWA index.html index.nginx-debian.html  
  
(avbogdanyuk@ avbogdanyuk)-[/var/www/html]  
$ sudo chmod -R 777 DVWA
```

Права доступа

Чтобы настроить DVWA, нужно перейти в каталог `/dvwa/config`, затем проверяю содержимое каталога. Создаем копию файла, используемого для настройки DVWA `config.inc.php.dist` с именем `config.inc.php`. (рис. 4).

```
(avbogdanyuk@avbogdanyuk)-[/var/www/html]
$ cd DVWA/config

(avbogdanyuk@avbogdanyuk)-[/var/www/html/DVWA/config]
$ ls
config.inc.php.dist

(avbogdanyuk@avbogdanyuk)-[/var/www/html/DVWA/config]
$ sudo cp config.inc.php.dist config.inc.php

(avbogdanyuk@avbogdanyuk)-[/var/www/html/DVWA/config]
$ ls
config.inc.php  config.inc.php.dist
```

config.inc.php

Далее открываю файл в текстовом редакторе и изменяю данные об имени пользователя и пароле (рис. 5).

```
avbogdanyuk@avbogdanyuk: /var/www/html/DVWA/config
Файл Действия Правка Вид Справка
GNU nano 8.2 config.inc.php *
# WARNING: The database specified under db_database WILL BE ENTI
# Please use a database dedicated to DVWA.
#
# If you are using MariaDB then you cannot use root, you must use
# See README.md for more information on this.
$_DVWA = array();
$_DVWA['db_server'] = getenv('DB_SERVER') ?: '127.0.0.1';
$_DVWA['db_database'] = 'dvwa';
$_DVWA['db_user'] = 'userDVWA';
$_DVWA['db_password'] = 'dvwa';
$_DVWA['db_port'] = 3306;
```

Изменяю данные

По умолчанию в Kali Linux установлен mysql, поэтому можно его запустить без предварительного скачивания, далее выполняю проверку, запущен ли процесс (рис. 6).

```
(avbogdanyuk@avbogdanyuk)-[/var/www/html/DVWA/config]
$ sudo systemctl start mysql
```

mysql

Авторизируюсь в базе данных от имени пользователя root. Появляется командная строка с приглашением "MariaDB", далее создаем в ней нового пользователя, используя учетные данные из файла `config.inc.php` (рис. 7).

```
(avbogdanyuk@avbogdanyuk)-[~]
$ sudo mysql -u root -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 31
Server version: 11.4.3-MariaDB-1 Debian n/a

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Support MariaDB developers by giving a star at https://github.com/MariaDB/server
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement
```

Авторизация

Необходимо настроить сервер apache2, перехожу в соответствующую директорию. В файле php.ini нужно будет изменить один параметр, поэтому открываю файл в текстовом редакторе (рис. 8).

```
(avbogdanyuk@avbogdanyuk)-[~]
$ cd /etc/php/8.2/apache2

(avbogdanyuk@avbogdanyuk)-[/etc/php/8.2/apache2]
$ sudo nano php.ini
```

apache2

Запускаем службу веб-сервера apache и проверяем, запущена ли служба (рис. 9).

```
(avbogdanyuk@avbogdanyuk)-[/etc/php/8.2/apache2]
$ sudo systemctl start apache2

(avbogdanyuk@avbogdanyuk)-[/etc/php/8.2/apache2]
$ systemctl status start apache2
```

apache2

5 Выводы

В ходе выполнения лабораторной работы была установлена DVWA в гостевую систему к Kali Linux.